Cyber Security Risk Qualitative Assessment Report
Remotely piloted fleet for goods delivery

EXECUTIVE SUMMARY

This document briefly describes the qualitative risk assessment performed on a remotely piloted fleet system used for goods delivery, based on the SECRAM framework [1].

The analysis identified key vulnerabilities in communication integrity, authentication, and infrastructure resilience. **Four primary asset categories** were defined, **Connections, Protocol & Monitoring, Information, and Security**, with critical components such as UAV-UTM communication, crash protocols, internal drone data, and encryption services. Supporting assets like network routers, servers, and communication protocols were found to be exposed to high-impact threats, including Man-in-the-Middle attacks, unauthorized access, protocol exploits, and OTA update vulnerabilities. These could compromise system availability, integrity, and safety. Recommended mitigations include **strong mutual authentication**, **encryption**, **intrusion detection systems**, **secure configurations**, **MFA**, and signed **OTA** updates. Emphasis is placed on securing both cyber and physical elements of the system through a layered defense strategy. The complete threat and control mapping is detailed in the supporting document *SecRAM-Secream_AF_FP.xlsx*.

Work submitted in partial fulfillment for the course of Cyber Security Risk Assessment - University of Trento - a.a. 2024/2025

This work is original work, has been done by the undersigned student and has not been copied or otherwise derived from the work of others not explicitly cited and quoted. The undersigned students are aware that plagiarism is an offence which may lead to failure of the course and more severe sanctions.

NAME, SURNAME, STUDENT-ID : Annachiara Fortuna 248721 - Francesco Poinelli 258857

TARGET OF EVALUATION

The evaluation focuses on a fleet of **remotely piloted Unmanned Aerial Vehicles (UAVs)** used for commercial purposes. The primary function of the fleet is the **transportation of goods** that do not require special handling, such as food, groceries, or general merchandise. The UAVs considered are drones, so their dimension is limited, as well as the size of the goods that they can successfully carry [2].

The system is designed to operate fully **autonomously**, although human intervention is possible in the event of unexpected situations, alerts, or other rare issues [3]. The main controller of the system is a network of **Unmanned Traffic Management (UTM)** units, which operate independently, sharing only the necessary information to remain synchronized [4]. Each UTM is responsible for managing the UAVs under its jurisdiction. It incorporates mechanisms to calculate the optimal trajectory for each UAV based on its destination and other relevant factors, such as the surrounding map, regulations concerning restricted areas and weather conditions along the flight path. Information about air traffic in the area is also considered to ensure safe operations and prevent collisions [5].

Each UAV is equipped with **sensors** that monitor its internal state to determine whether it can successfully complete the flight. Some of these sensors also verify that the UAV is following the planned route. In case of issues, inconsistencies, or changes in conditions (e.g., weather), the UTM is responsible for recalculating and updating the flight path. UAV sensors are also used to detect and avoid unexpected obstacles, which may occur due to rare path calculation errors, unforeseen events or new buildings which may not appear in classical mappings.

The UAV and the UTM are expected to maintain **communication** throughout the flight. If communication is lost, predefined emergency protocols are in place to handle such situations, enhancing the system's resilience. All data exchanged within the system is encrypted using secure libraries, and any stored data is kept in a secure database to prevent data leaks, theft, and legal issues.

As said the UTM is used as the core of the organization of the whole system, for this reason its electrical power distribution is protected and supported by **backup** systems. Being so important, access to it is limited and protected with an **authentication service**, both for drones and operators.

SUMMARY OF FINDINGS

From the completed analysis, several major issues have emerged. Given their similar application across the system, these challenges often share common mitigation strategies. As outlined, each UTM (Unmanned Traffic Management) component requires extensive data to accurately calculate UAV (Unmanned Aerial Vehicle) trajectories for the delivery of goods. Some data sources, such as regulations and legal frameworks, change infrequently, while others, like real-time weather forecasts and air traffic information, require constant updates and retrieval. In this context, a key concern is ensuring the authenticity and integrity of the information. A primary solution involves utilizing redundant data sources where feasible, performing signature verification, and employing secure communication protocols.

Communication channels represent another critical area of concern. They are vulnerable to various attacks that can compromise confidentiality, integrity, and availability. Gaining control over a communication channel could result in significant disruptions, potentially leading to complete UAV hijacking. Common threats include Man-in-the-Middle (MitM) attacks and unauthorized access to communication endpoints. While endpoint protection must be tailored to each component, communication integrity can be safeguarded through strong mutual authentication and robust encryption mechanisms.

Security mechanisms are embedded throughout the system, particularly in authentication services for both operators and UAVs, and in encryption of data in transit and at rest. However, these protections may be compromised by misconfiguration or the use of outdated technologies. Mitigation involves enforcing the use of current best practices and secure configurations. Specifically, operator authentication can be strengthened through **Multi-Factor Authentication** (**MFA**) and by disabling unused accounts.

The **physical infrastructure** supporting the UTM is also a potential target, susceptible to damage or degradation over time. Regular inspections and preventive maintenance are necessary to mitigate this risk [6].

Servers form the computational backbone of the UTM system. They must be protected against software-based threats and malware that could compromise availability or control. Effective measures include proper firewall configuration, up-to-date antivirus solutions, and the adoption of a zero-trust architecture to reduce the impact of insider threats.

Lastly, the system depends on numerous **software components**, including external libraries. Regular security assessments of these third-party resources are essential to reduce the risk of exploitation that could compromise the system's integrity. In addition, keeping all software components up-to-date is a fundamental practice to ensure protection against newly discovered vulnerabilities and to maintain a strong overall security structure.

RISK ANALYSIS

At ***Step 1*** we identified the primary assets and assessed their impact (see Table 1.1 and 1.2 in SecRAM-Secream_AF_FP.xlsx). To organize the analysis more effectively, we grouped the primary assets into four categories: **Connections, Protocol + Monitoring, Information** and **Security.** For each category, we selected the most critical assets based on their impact across the CIA criteria (Confidentiality, Integrity, Availability) and the SESAR Security Impact Areas (**IA1–IA7**)[1].
The most relevant primary assets identified are:

- [A] **Communication between UAV and UTM (Connections)**: A compromise of its availability or integrity could lead to flight mismanagement or even collisions, with possible consequences on **IA2 (Capacity)** and **IA3 (Performance)**.
- [B] **Crash Protocol (Protocol + Monitoring)**: Loss of integrity or availability in this asset could cause delayed or failed crash handling procedures, severely affecting **IA1 (Personnel)** and **IA5 (Branding)**.
- [C] **Internal Drone State Information (Information)**: Any compromise in the confidentiality or accuracy of this data can mislead control systems or operators, with possible impacts on **IA3 (Performance)** and **IA5 (Branding)**.
- [D] **Data Transit Encryption (Security)**: Compromise in these services can lead to spoofing or data interception, threatening **IA2 (Capacity)** and **IA3 (Performance)**.

At ***Step 2*** we identified supporting assets for the list of primary assets from Step 1. For each primary asset, we indicate the linked supporting assets (see Table 1.3 in the document SecRAM-Secream_AF_FP.xlsx).

- Network routers [A][B][C][D]
- Firewall [A][B][C][D]
- Communication protocols (e.g. WiFi) [A][B][C][D]
- Servers [A][B][C][D]
- RF transceiver models [A][C][D]
- Public key infrastructure (PKI) [A][B][D]
- Encryption libraries (e.g., AES, TLS) [A][D]
- Secure communication protocols (SSL/TLS, IPsec) [A][D]
- Onboard safety logic (microcontroller or flight controller) [B][C]
- Emergency handling UAV software [B][C]
- Identity and access management systems [A]
- Navigation software stack [B]
- Monitoring software [B]

To streamline the analysis, we selected only the **most critical supporting assets**, those **connected to at least three primary assets**. These include key components such as network routers, firewalls, communication protocols, and servers, which ensure secure communication, system integrity, and service availability across multiple UAV functionalities. Their centrality makes them priority targets for threat and risk evaluation.

In ***Step 3*** we identified threats to our supporting assets from Step 2 (see Tables 2.1 and 2.2 in SecRAM-Secream_AF_FP.xlsx).

- **Network routers** are exposed to **Man-In-The-Middle** attacks due to weak authentication mechanisms, **unauthorized access** risks stemming from weak or default passwords, and **Denial of Service (DoS)** attacks caused by the absence of rate limiting or other DoS protections.
- **Firewalls** face threats of **unauthorized access** owing to weak authentication and default credentials, **exploitation of misconfigurations** caused by human errors and poor logging practices, and **remote code execution (RCE)** vulnerabilities resulting from bugs in firewall software.
- **Communication protocols** are vulnerable to **exploitation of protocol bugs**, including **buffer overflow** possibilities, and **sniffing attacks** due to weak or absent encryption.
- **Servers** are at risk of **unauthorized access** because of weak or missing authentication mechanisms, **insider threats** from both intentional and accidental misuse, and **malware infections** due to a lack of antivirus protection.
- **RF transceiver modules** are susceptible to **over-the-air (OTA) update attacks** because of missing authentication or verification during the update process.

These conclusions are based on the observed weaknesses and vulnerabilities documented in the system components[7].
At ***Step 4*** we evaluated the impact and risk level of the threats identified in Step 3 (see Table 3.2 in the document SecRAM-Secream_AF_FP.xlsx). The main threats that should be mitigated are the following:

Threat	Risk Level	Impact on CIA
Man-In-The-Middle on **Network routers**	**Very High**	**C I**
Unauthorized Access to **Network routers, Firewalls** and **Servers**	**Very High**	**C I A**
Protocol bug exploitation and **Sniffing** on **Communication protocols**	**High**	**C I A and C**
Insiders threats and **Malware infection** on **Servers**	**Very High**	**C I A**
Over the air update attacks on **RF transceiver modules**	**High**	**C I A**

In Step 5 we proposed a set of security controls to mitigate the main threats identified in Steps 3–4 (see Table 5 in the document SecRAM-Secream_AF_FP.xlsx). Among them we consider the most important ones. For example, to reduce the risk of Man-In-The-Middle attacks on routers, we proposed strong mutual authentication and log inspection, as recommended in recent studies on UAV communication integrity [8]. To counter unauthorized access, we suggested strong password policies, Multi-Factor Authentication (MFA), and login auditing. For communication protocols, we recommended encrypted payloads, hardened protocol versions, and IDS alerts to mitigate sniffing and protocol bugs, in line with proposals for MAVLink hardening and secure protocol monitoring [9][10]. Server threats are addressed through MFA, disabling unused accounts, least privilege access, zero trust architecture, and malware protection [10]. Lastly, signed over-the-air (OTA) updates and logging were proposed for securing RF transceivers, consistent with security reviews and firmware analyses in recent UAV literature [11][12].
The complete summary of results can be found in the document SecRAM-Secream_AF_FP.xlsx submitted as an integral part of the current report.

ANNEX

An integral part of the report we attach the following documents:

1. Excel document reporting the application of SESAR SecRAM method (see file Secream_AF_FP.xlsx).

REFERENCES

[1] SESAR Joint Undertaking, *Security Risk Assessment Methodology (SECRAM)*, SESAR 2020 Project Deliverable D107, 2021. Available:https://www.sesarju.eu/sites/default/files/documents/transversal/SESAR%202020%20-%20Security%20Reference%20Material%20Guidance.pdf

[2] Debnath D, Vanegas F, Sandino J, Hawary AF, Gonzalez F. A Review of UAV Path-Planning Algorithms and Obstacle Avoidance Methods for Remote Sensing Applications. *Remote Sensing*. 2024; 16(21):4019. https://doi.org/10.3390/rs16214019

[3] Kopardekar, Parmial. Unmanned Aerial System (UAS) Traffic Management (UTM): Enabling Low-Altitude Airspace and UAS Operations. NASA/TM—2014–218299. Moffett Field, CA: NASA Ames Research Center, 2014. http://www.nasa.gov.

[4] Airbus. *Blueprint for the Sky: The Roadmap for the Safe Integration of Autonomous Aircraft*. A³ by Airbus, 2018. https://www.utmblueprint.com/

[5] Unmanned Aircraft Systems Traffic Management (UTM) – A Common Framework with Core Principles for Global Harmonization Edition 4. AAvailable: https://www.icao.int/safety/UA/Documents/UTM%20Framework%20Edition%204.pdf

[6] European Union Aviation Safety Agency (EASA). *AMC-20 Amendment 18: General Acceptable Means of Compliance for Airworthiness of Products, Parts and Appliances*. ED Decision 2020/006/R. Cologne, Germany: EASA, June 24, 2020. https://www.easa.europa.eu/en/document-library/agency-decisions/ed-decision-2020006r.

[7] Branco, Bruno & Silva, José & Correia, Miguel. (2025). Cyber Attacks on Commercial Drones: A Review. IEEE Access. PP. 1-1. 10.1109/ACCESS.2025.3527698.

[8] Ouadah, Meriem, e Fatiha Merazka. "Securing UAV Communication: Authentication and Integrity." *arXiv*, October 6, 2024. https://arxiv.org/abs/2410.09085.

[9] Dixit, Bhavya, Ananthapadmanabhan A., Adheeba Thahsin, Saketh Pathak, Gaurav S. Kasbekar, e Arnab Maity. "A Novel Cipher for Enhancing MAVLink Security: Design, Security Analysis, and Performance Evaluation Using a Drone Testbed." *arXiv*, April 29, 2025. https://arxiv.org/abs/2504.20626.

[10] Hassija, Vikas, Vinay Chamola, Adhar Agrawal, Adit Goyal, Nguyen Cong Luong, Dusit Niyato, F. Richard Yu, e Mohsen Guizani. "Fast, Reliable, and Secure Drone Communication: A Comprehensive Survey." *IEEE Communications Surveys & Tutorials* 23, n. 4 (2021): 2802–2832. https://doi.org/10.1109/COMST.2021.3097916.

[11] "Cyber4Drone: A Systematic Review of Cyber Security and Forensics in Unmanned Aerial Vehicles." *Drones* 7, n. 7 (luglio 2023): 430. https://doi.org/10.3390/drones7070430.

[12] "DJI Mavic 3 Drone Research Part 1: Firmware Analysis." Nozomi Networks Blog, marzo 2023.